WEEK 7 — Portfolio Artifact Proposal & Outline

Assignment Name: Security+ Incident Response Summary Portfolio
Final Security+ Portfolio Artifact (GitHub Link)
Due: End of Week 7

Instructions

This is the **final graded submission** of your Security+ portfolio artifact.

Requirements

Your GitHub repository must contain:

- A clearly written README.md
- A polished, professional artifact.pdf
- Correct folder structure

Only **one artifact** is required.

Security Reminder

Do **not** include:

- Passwords or credentials
- API keys or tokens
- Real company data
- Personal identifying information

Submit in Blackboard

Submit:

- A link to your GitHub portfolio repository

Blackboard is the official submission record. GitHub is used to store your professional artifact.

Incident Response Plan (IRP)

Stocky Boots – Ransomware Incident Response Plan

---

1. Introduction

Stocky Boots is a locally owned retail and e-commerce company specializing in work and outdoor footwear. The organization operates a physical storefront and an online ordering platform, relying heavily on digital infrastructure to manage inventory, sales transactions,

payroll, and vendor relationships. Given the increasing threat landscape targeting small and medium-sized businesses (SMBs), Stocky Boots recognizes the need for a structured and comprehensive Incident Response Plan (IRP) to effectively detect, respond to, and recover from cybersecurity incidents, particularly ransomware attacks.

This Incident Response Plan establishes policies, procedures, roles, and responsibilities to ensure a coordinated response to security incidents while minimizing operational disruption, financial loss, and reputational damage.

---

2. Purpose and Scope

2.1 Purpose

The purpose of this IRP is to:

- Provide a standardized approach for responding to cybersecurity incidents.
- Minimize damage and recovery time following a ransomware attack.
- Protect sensitive customer, employee, and business data.
- Ensure compliance with applicable data protection laws and regulations.
- Improve future security posture through lessons learned.

2.2 Scope

This plan applies to:

- All employees and contractors.
- All information systems, including:
    - Point-of-sale (POS) systems
    - E-commerce servers
    - Workstations and laptops
    - Network infrastructure
    - Cloud-based services
    - Backup systems

The IRP specifically addresses ransomware attacks but may also be adapted to other cybersecurity incidents such as data breaches, phishing campaigns, or insider threats.

---

3. Incident Response Team (IRT)

Stocky Boots will establish an Incident Response Team (IRT) consisting of the following roles:

3.1 Incident Response Manager

- Oversees response efforts.
- Coordinates communication between departments.
- Makes decisions regarding system shutdowns and external reporting.

3.2 IT Lead / Security Administrator

- Conducts technical investigation.
- Implements containment, eradication, and recovery measures.
- Coordinates with third-party cybersecurity vendors.

3.3 Communications Lead

- Manages internal and external communications.
- Coordinates customer notifications and media statements.

3.4 Legal Advisor

- Ensures compliance with breach notification laws.
- Advises on ransom payment implications and liability exposure.

3.5 Executive Leadership

- Approves major business decisions.
- Coordinates with insurance providers and law enforcement.

---

4. Incident Response Lifecycle

This IRP follows the NIST Incident Response Lifecycle:

1. Preparation
2. Identification
3. Containment
4. Eradication
5. Recovery
6. Lessons Learned

---

5. Preparation

Preparation reduces the likelihood and impact of ransomware incidents.

5.1 Preventive Controls

Stocky Boots will implement:

- Multi-Factor Authentication (MFA) for administrative accounts.
- Endpoint Detection and Response (EDR) software.
- Network segmentation separating POS, servers, and employee devices.
- Regular patch management and vulnerability scanning.
- Offline and cloud-based encrypted backups.
- Email filtering and phishing detection tools.
- Employee cybersecurity awareness training.

5.2 Backup Strategy

- Daily automated backups.
- Weekly offline backup copies.
- Monthly backup restoration testing.
- Backup encryption to prevent compromise.

5.3 Documentation

Maintain updated:

- Network diagrams.
- Asset inventory lists.
- Contact lists for incident response stakeholders.
- Cyber insurance documentation.

---

6. Identification

6.1 Indicators of Ransomware

Ransomware indicators may include:

- Encrypted files with altered extensions.
- Ransom notes demanding cryptocurrency payment.
- Disabled antivirus or security controls.
- Unusual administrative logins.
- Unexpected file deletions or modifications.

6.2 Initial Actions

Upon detection:

- Document date, time, and systems affected.
- Capture screenshots of ransom notes.
- Preserve logs and evidence.
- Notify the Incident Response Manager immediately.

Incident severity is classified as **Critical** if business operations are disrupted or sensitive data is potentially exposed.

---

7. Containment

7.1 Short-Term Containment

- Disconnect infected devices from the network.
- Disable shared drives and file servers.
- Block malicious IP addresses.
- Disable compromised user accounts.
- Prevent further ransomware execution.

7.2 System Isolation

- Segregate affected VLANs.
- Temporarily suspend online sales platform if required.
- Prevent lateral movement within the network.

7.3 Communication

- Notify executive leadership.
- Consult legal counsel.
- Notify cyber insurance provider.
- Avoid communicating directly with attackers without legal consultation.

---

8. Eradication

After containment, the root cause must be eliminated.

8.1 Root Cause Analysis

- Identify initial infection vector (e.g., phishing email).
- Analyze malware samples.
- Review firewall and authentication logs.
- Confirm privilege escalation methods used.

8.2 Removal Actions

- Reimage infected systems.
- Remove malicious files and registry entries.
- Patch exploited vulnerabilities.
- Reset all administrative credentials.
- Revoke exposed API keys and service accounts.

External cybersecurity consultants may be engaged to validate complete eradication.

---

9. Recovery

9.1 System Restoration

- Restore files from verified offline backups.
- Validate integrity of restored data.
- Gradually reconnect systems to the network.
- Monitor for reinfection signs.

9.2 Operational Restoration

- Resume POS operations.
- Restore e-commerce platform.
- Notify customers if data exposure occurred.
- Implement heightened monitoring for 30–60 days post-incident.

9.3 Ransom Decision

Stocky Boots maintains a policy discouraging ransom payment unless:

- No viable backups exist.
- Legal and executive approval is granted.
- Law enforcement consultation has occurred.

---

10. Communication Plan

10.1 Internal Communication

- Inform employees of operational impacts.
- Provide instructions on secure password resets.
- Reinforce phishing awareness.

10.2 External Communication

- Notify affected customers if required.
- Report to regulatory authorities if mandated.
- Provide public statement if incident becomes public.

Transparency is critical to maintaining customer trust.

---

11. Post-Incident Review and Lessons Learned

Within two weeks of incident resolution, the IRT will conduct a formal review.

11.1 Review Objectives

- Evaluate response effectiveness.
- Identify gaps in detection or containment.
- Assess financial and reputational impact.
- Update policies and controls accordingly.

11.2 Security Improvements

- Implement stronger Zero Trust controls.
- Enhance logging and SIEM monitoring.
- Expand phishing simulations.
- Strengthen vendor risk management.
- Review cyber insurance coverage adequacy.

---

12. Business Impact Analysis

A ransomware incident may result in:

- 24–72 hours of downtime.
- Loss of sales revenue.
- Incident response consulting costs.
- Customer trust erosion.
- Potential regulatory penalties.

However, proper preparation and tested backups significantly reduce long-term impact.

---

13. Plan Maintenance

This IRP will be:

- Reviewed annually.
- Updated after major system changes.
- Revised after any significant incident.
- Tested through tabletop exercises twice per year.

---

14. Conclusion

Ransomware represents a significant threat to small businesses such as Stocky Boots. A structured Incident Response Plan ensures that the organization can rapidly detect, contain, and recover from attacks while minimizing operational and financial damage. By adopting proactive security measures, maintaining tested backups, training employees, and following the NIST incident response lifecycle, Stocky Boots can strengthen resilience against future cyber threats.

Preparedness, coordination, and continuous improvement remain essential components of an effective cybersecurity posture.

AI**: IRP was collated and edited with the help of SAGE AI.